รายงานโครงการ

การติดตั้ง ความปลอดภัย และการตรวจสอบ เซิร์ฟเวอร์ WordPress บน Microsoft Azure

(WordPress Server Deployment, Security Hardening and Monitoring on Microsoft Azure)

จัดทำโดย

ณัฐกิตติ์	อารักษ์วาณิช	67160052
วิศรุต	เกตุผดุง	67160055
เมธาสิทธิ์	อุดมธนภัทร	67160077
อดิศร	ตรีสินธ์	67160081
รัก	รักศรี	67160104
พิพัฒพล	ทองรวย	67160264
วิศรุต	ชาติพจน์	67160271
ณัฐภัทร	สักแกแก้ว	67160420

เสนอ

ผศ.ภูสิต กุลเกษม

รายงานเล่มนี้เป็นส่วนหนึ่งของวิชา Computer Networks

รหัสวิชา 88633065

ภาคเรียนที่ 1 ปีการศึกษา 2569

คณะวิทยาการสารสนเทศ สาขาวิทยาการคอมพิวเตอร์

คำนำ

รายงานฉบับนี้จัดทำขึ้นเพื่อรวบรวมและบันทึกขั้นตอนการดำเนินงานของโครงงานติดตั้ง รักษาความปลอดภัย และตรวจสอบเซิร์ฟเวอร์ WordPress ที่โฮสต์บนเครื่องเสมือน (Virtual Machine) ของ Microsoft Azure ตั้งแต่การเตรียมโครงสร้างพื้นฐาน การติดตั้งซอฟต์แวร์ในรูปแบบ LEMP Stack การเสริมความปลอดภัยหลายชั้น การเพิ่มประสิทธิภาพการให้บริการ ไปจนถึงการสร้างระบบตรวจสอบพฤติกรรมการเข้าใช้งานด้วย Dashboard ที่พร้อมนำข้อมูลไปให้ปัญญาประดิษฐ์ (AI) วิเคราะห์ต่อได้

ผู้จัดทำหวังเป็นอย่างยิ่งว่ารายงานฉบับนี้จะเป็นประโยชน์ต่อผู้ที่สนใจการดูแลเซิร์ฟเวอร์เว็บไซต์บนคลาวด์ และสามารถใช้เป็นแนวทางอ้างอิงในการสร้างระบบที่มีความปลอดภัยและตรวจสอบย้อนหลังได้ หากมีข้อผิดพลาดประการใดในรายงานฉบับนี้ ผู้จัดทำขอน้อมรับไว้และขออภัยมา ณ ที่นี้

คณะผู้จัดทำ

สารบัญ

คำนำ ..... ก

บทที่ 1 บทนำ 1

1.1 ความเป็นมาและความสำคัญของโครงงาน 1

1.2 วัตถุประสงค์ของโครงงาน 1

1.3 ขอบเขตของโครงงาน 2

1.4 ประโยชน์ที่คาดว่าจะได้รับ 2

บทที่ 2 ทฤษฎีและเทคโนโลยีที่เกี่ยวข้อง 3

2.1 คลาวด์คอมพิวติ้งและ Microsoft Azure Virtual Machine 3

2.2 ระบบปฏิบัติการ Ubuntu Server 24.04 LTS 3

2.3 WordPress 4

2.4 สถาปัตยกรรม LEMP Stack 4

2.4.1 Nginx 4

2.4.2 PHP-FPM 5

2.4.3 MySQL 5

2.5 ระบบชื่อโดเมน DuckDNS และ HTTPS 5

2.5.1 ระบบชื่อโดเมนและ DuckDNS 5

2.5.2 การเข้ารหัสการสื่อสารด้วย HTTPS/TLS 6

2.6 ความปลอดภัยของ SSH และการยืนยันตัวตนด้วยกุญแจสาธารณะ (SSH Key Authentication) 6

2.7 Fail2ban 6

2.8 การกรองตามภูมิศาสตร์ (Geo-blocking) ด้วย iptables และ ipset 6

2.9 Browser Caching 7

2.10 GoAccess และ Cron 7

2.11 แนวคิดการป้องกันหลายชั้น (Defense in Depth) 8

บทที่ 3 การออกแบบและการดำเนินงาน 9
3.1 ภาพรวมและสถาปัตยกรรมของระบบ 9
3.1.1 ข้อมูลพื้นฐานของเซิร์ฟเวอร์ 9
3.1.2 สถาปัตยกรรมของระบบ 10
3.1.3 การไหลของข้อมูลเมื่อมีคำขอเข้าเว็บไซต์ 10
3.1.4 การออกแบบชั้นความปลอดภัย 11
3.2 เครื่องมือและซอฟต์แวร์ที่ใช้ 12
3.3 การเตรียมและสร้าง Azure Virtual Machine 13
3.4 การติดตั้งและกำหนดค่า LEMP Stack 13
3.5 การติดตั้งและตั้งค่า WordPress 14
3.5.1 การสร้างฐานข้อมูลและผู้ใช้ฐานข้อมูล 14
3.5.2 การติดตั้งไฟล์ WordPress 14
3.5.3 การตั้งค่า Server Block ของ Nginx 14
3.6 การกำหนด DNS และ HTTPS 15
3.6.1 การตั้งค่าโดเมนด้วย DuckDNS 15
3.6.2 การเปิดใช้งาน HTTPS ผ่าน Nginx Reverse Proxy 16
3.7 การกำหนดค่าความปลอดภัย SSH และ Fail2ban 17
3.7.1 การกำหนดความปลอดภัย SSH 17
3.7.2 การติดตั้งและตั้งค่า Fail2ban 18
3.8 การกำหนด Geo-blocking ด้วย iptables และ ipset 19
3.9 การกำหนด Browser Caching 20
3.10 การติดตั้ง GoAccess และตั้งเวลาอัปเดต Dashboard ด้วย Cron 21
3.10.1 การติดตั้งและใช้งาน GoAccess 21
3.10.2 การตั้งเวลาอัปเดตอัตโนมัติด้วย Cron 21
3.10.3 แนวทางการนำข้อมูลไปวิเคราะห์ด้วย AI 21

บทที่ 4 การทดสอบและวิเคราะห์ผล 23
4.1 วัตถุประสงค์และวิธีการทดสอบ 23
4.2 การทดสอบการเข้าถึงเว็บไซต์ WordPress และ LEMP Stack 24
4.3 การทดสอบ HTTPS และ DNS 25
4.4 การทดสอบ SSH Key Authentication 26
4.5 การทดสอบ Fail2ban 27
4.6 การทดสอบ Geo-blocking 28
4.7 การทดสอบ Browser Caching 29
4.8 การทดสอบ GoAccess และ Cron 30
บทที่ 5 สรุปผลและข้อเสนอแนะ 31
5.1 สรุปการดำเนินงานตามวัตถุประสงค์ 31
5.2 สรุปผลการทดสอบที่มีหลักฐานรองรับ 32
5.3 ข้อจำกัดของโครงงาน 32
5.4 ข้อเสนอแนะและแนวทางพัฒนาต่อไป 33
5.4.1 ข้อเสนอแนะที่สัมพันธ์กับข้อจำกัดและปัญหาในบทที่ 4 33
5.4.2 แนวทางพัฒนาต่อยอด 33
5.4.3 แนวทางการบำรุงรักษาเซิร์ฟเวอร์ 33
5.5 ความรู้ที่ได้รับและข้อคิดทิ้งท้าย 35
บรรณานุกรม 36

บทที่ 1 บทนำ

1.1 ความเป็นมาและความสำคัญของโครงงาน

ในปัจจุบันเว็บไซต์เป็นช่องทางหลักในการให้บริการข้อมูลและสื่อสารกับผู้ใช้งาน WordPress เป็นระบบจัดการเนื้อหา (Content Management System: CMS) ที่ได้รับความนิยมสูงมาก เนื่องจากติดตั้งง่าย มีปลั๊กอินและธีมให้เลือกจำนวนมาก อย่างไรก็ตาม ความนิยมดังกล่าวทำให้ WordPress ตกเป็นเป้าหมายของการโจมตีอยู่เสมอ เช่น การสุ่มรหัสผ่านหน้าเข้าสู่ระบบ การสแกนหาช่องโหว่ของปลั๊กอิน และการส่งคำขอจำนวนมากเพื่อรบกวนการให้บริการ

การนำเว็บไซต์ไปไว้บนคลาวด์สาธารณะอย่าง Microsoft Azure ช่วยให้ผู้ดูแลระบบควบคุมโครงสร้างพื้นฐานได้อย่างยืดหยุ่น แต่ก็หมายความว่าผู้ดูแลต้องรับผิดชอบความปลอดภัยของระบบปฏิบัติการและแอปพลิเคชันที่ติดตั้งบนเครื่องเสมือนด้วยตนเองตามแนวคิดความรับผิดชอบร่วมกัน (Shared Responsibility Model) กล่าวคือ ผู้ให้บริการคลาวด์ดูแลความปลอดภัยของศูนย์ข้อมูลและฮาร์ดแวร์ ส่วนลูกค้าต้องดูแลการตั้งค่าระบบปฏิบัติการ เครือข่าย และข้อมูลของตน

โครงงานนี้จึงถูกออกแบบให้เป็นแนวทางปฏิบัติแบบครบวงจร ตั้งแต่การติดตั้งเว็บเซิร์ฟเวอร์ที่มีประสิทธิภาพสูง การเสริมความปลอดภัยหลายชั้น (Defense in Depth) ไปจนถึงการเฝ้าระวังด้วยระบบวิเคราะห์ล็อกอัตโนมัติ เพื่อให้เว็บไซต์ WordPress ทำงานได้รวดเร็ว ปลอดภัย และตรวจสอบย้อนหลังได้

1.2 วัตถุประสงค์ของโครงงาน

โครงงานนี้มีวัตถุประสงค์ดังต่อไปนี้

1. เพื่อติดตั้งและกำหนดค่าเซิร์ฟเวอร์ WordPress ในสถาปัตยกรรม LEMP Stack (Linux, Nginx, MySQL, PHP-FPM) บน Microsoft Azure Virtual Machine

2. เพื่อรักษาความปลอดภัยของการเข้าถึงเซิร์ฟเวอร์ด้วยการตั้งค่า SSH แบบใช้กุญแจสาธารณะ (PKI) และการเข้ารหัสการรับส่งข้อมูลด้วย HTTPS
3. เพื่อป้องกันการโจมตีแบบสุ่มรหัสผ่าน (Brute-force) ด้วย Fail2ban และจำกัดการเข้าถึงเว็บไซต์ให้เฉพาะหมายเลข IP ภายในประเทศไทยด้วย ipset และ iptables
4. เพื่อเพิ่มประสิทธิภาพการโหลดหน้าเว็บไซต์ด้วย Browser Caching ของ Nginx
5. เพื่อสร้างระบบตรวจสอ[และวิเคราะห์ล็อกด้วยGoAccessที่อัปเดตอัตโนมัติและเตรียมข้อมูลให้พร้อมสำหรับการวิเคราะห์ด้วย AI
6. เพื่อเรียนรู้และบันทึกแนวปฏิบัติปัญหาและข้อเสนอแนะในการดูแลเซิร์ฟเวอร์เว็บไซต์บนคลาวด์อย่างต่อเนื่อง

1.3 ขอบเขตของโครงงาน

ขอบเขตของโครงงานประกอบด้วยงานต่อไปนี้

- ติดตั้งและกำหนดค่าเซิร์ฟเวอร์ WordPress บน Azure Virtual Machine ที่ใช้ Ubuntu 24.04 LTS
- กำหนดความปลอดภัยของการเข้าถึงด้วย SSH แบบ PKI และเปิดใช้งาน HTTPS ผ่าน Nginx
- ติดตั้ง Fail2ban เพื่อตรวจจับและบล็อก IP ที่พยายามเข้าสู่ระบบผิดปกติ
- จำกัดการเข้าถึงพอร์ต 80 และ 443 เฉพาะ IP ในประเทศไทยด้วย ipset และ iptables
- ตั้งค่า Browser Caching สำหรับไฟล์ Static ใน Nginx
- ติดตั้ง GoAccess สร้าง Dashboard และตั้ง Cron Job อัปเดตทุก 5 นาที

ทั้งนี้ โครงงานไม่รวมการพัฒนาธีมหรือปลั๊กอินของ WordPress และไม่รวมการออกแบบเนื้อหาของเว็บไซต์

1.4 ประโยชน์ที่คาดว่าจะได้รับ

- ได้เซิร์ฟเวอร์ WordPress ที่ทำงานเร็วและมีโครงสร้างชัดเจน ดูแลรักษาได้ง่าย
- ลดความเสี่ยงจากการโจมตีแบบสุ่มรหัสผ่านและการเข้าถึงจากต่างประเทศ
- มีข้อมูลสถิติการเข้าใช้งานและพฤติกรรมต้องสงสัยที่ตรวจสอบได้ตลอดเวลา
- ได้แนวทางและเอกสารอ้างอิงที่นำไปประยุกต์ใช้กับโครงงานเว็บไซต์อื่นได้

บทที่ 2 ทฤษฎีและเทคโนโลยีที่เกี่ยวข้อง

บทนี้อธิบายหลักการและเทคโนโลยีที่ใช้ในโครงงานเพื่อให้เข้าใจหน้าที่และเหตุผลของการเลือกใช้เครื่องมือแต่ละชนิด รวมทั้งบทบาทของเครื่องมือเหล่านั้นในระบบโดยรวม

2.1 คลาวด์คอมพิวติ้งและ Microsoft Azure Virtual Machine

คลาวด์คอมพิวติ้ง (Cloud Computing) คือรูปแบบการให้บริการทรัพยากรด้านคอมพิวเตอร์ เช่น เครื่องแม่ข่าย พื้นที่จัดเก็บ และเครือข่ายผ่านอินเทอร์เน็ตตามความต้องการใช้งาน Microsoft Azure Virtual Machine เป็นบริการประเภทโครงสร้างพื้นฐานเป็นบริการ (Infrastructure as a Service: IaaS) ที่ให้ผู้ใช้สร้างเครื่องเสมือนและเลือกระบบปฏิบัติการ ขนาดทรัพยากร และการตั้งค่าเครือข่ายได้เอง (Microsoft, n.d.) ผู้ใช้มีสิทธิ์ควบคุมระบบปฏิบัติการเต็มรูปแบบจึงต้องรับผิดชอบการอัปเดตแพตช์ และการตั้งค่าความปลอดภัยด้วยตนเอง

ในส่วนของเครือข่าย Azure มีกลุ่มความปลอดภัยเครือข่าย (Network Security Group: NSG) ทำหน้าที่เป็นไฟร์วอลล์ระดับเครือข่ายก่อนที่ทราฟฟิกจะเข้าถึงเครื่องเสมือนผู้ดูแลสามารถกำหนดกฎอนุญาตหรือปฏิเสธตามพอร์ตและหมายเลข IP ได้ ซึ่งทำงานเสริมกับไฟร์วอลล์ภายในระบบปฏิบัติการ

2.2 ระบบปฏิบัติการ Ubuntu Server 24.04 LTS

Ubuntu เป็นระบบปฏิบัติการลีนุกซ์ที่ได้รับความนิยมในการใช้งานเป็นเซิร์ฟเวอร์ (Canonical Ltd., n.d.) รุ่น 24.04 LTS(NobleNumbat)เป็นรุ่นที่ให้การสนับสนุนระยะยาว(LongTermSupport)ซึ่งได้รับการอัปเดตความปลอดภัยเป็นระยะเวลานาน เหมาะกับการใช้งานจริงที่ต้องการความเสถียร มีตัวจัดการแพ็กเกจ apt ที่ช่วยให้ติดตั้งและอัปเดตซอฟต์แวร์ได้สะดวก จึงถูกเลือกเป็นระบบปฏิบัติการหลักของเซิร์ฟเวอร์ในโครงงานนี้

2.3 WordPress

WordPress เป็นระบบจัดการเนื้อหา (CMS) ที่มีปลั๊กอินและธีมให้เลือกจำนวนมาก ทำงานด้วยภาษา PHP และจัดเก็บเนื้อหา โพสต์ หน้า ความคิดเห็น ข้อมูลผู้ใช้ และการตั้งค่าต่างๆ ไว้ในฐานข้อมูล MySQL ด้วยความนิยมที่สูง WordPress จึงเป็นเป้าหมายของการสุ่มรหัสผ่านหน้าเข้าสู่ระบบ การสแกนหาช่องโหว่ของปลั๊กอิน และการส่งคำขอจำนวนมากเพื่อรบกวนบริการ ดังที่กล่าวในหัวข้อ 1.1 ผู้พัฒนา WordPress มีแนวทางการเสริมความปลอดภัยเผยแพร่ไว้ (WordPress.org, n.d.) โครงงานนี้เน้นมาตรการระดับระบบและเครือข่ายที่ล้อมรอบ WordPress ส่วนการอัปเดตแกนหลัก ธีม และปลั๊กอิน ยังเป็นหน้าที่ของผู้ดูแลที่ต้องดำเนินการสม่ำเสมอ

2.4 สถาปัตยกรรม LEMP Stack

LEMP Stack คือชุดซอฟต์แวร์สำหรับให้บริการเว็บแอปพลิเคชัน ประกอบด้วย Linux เป็นระบบปฏิบัติการ Nginx (อ่านว่า “เอนจิน-เอ็กซ์”) เป็นเว็บเซิร์ฟเวอร์ MySQL เป็นระบบจัดการฐานข้อมูล และ PHP เป็นภาษาสำหรับประมวลผลฝั่งเซิร์ฟเวอร์ โดยในโครงงานนี้ใช้ PHP-FPM แทนการฝัง PHP ไว้ในเว็บเซิร์ฟเวอร์โดยตรง

2.4.1 Nginx

Nginx เป็นเว็บเซิร์ฟเวอร์และรีเวิร์สพร็อกซีที่ออกแบบด้วยสถาปัตยกรรมแบบขับเคลื่อนด้วยเหตุการณ์ (Event-driven) ทำให้รองรับการเชื่อมต่อพร้อมกันจำนวนมากโดยใช้หน่วยความจำน้อย (Nginx, Inc., n.d.) จุดเด่นคือการให้บริการไฟล์ Static ได้รวดเร็ว การทำ TLS Termination สำหรับ HTTPS และการส่งต่อคำขอที่เป็น PHP ไปยัง PHP-FPM ผ่านโปรโตคอล FastCGI เวอร์ชันที่ใช้ในโครงงานคือ 1.24.0

เหตุผลที่เลือกใช้: Nginx ใช้ทรัพยากรน้อยกว่า Apache เมื่อมีการเชื่อมต่อพร้อมกันจำนวนมาก และให้บริการไฟล์ Static ได้รวดเร็ว เหมาะกับเว็บไซต์ WordPress ที่มีรูปภาพและสคริปต์จำนวนมาก

2.4.2 PHP-FPM

PHP-FPM (FastCGI Process Manager) เป็นตัวจัดการกระบวนการของ PHP ที่แยกการประมวลผลออกจากเว็บเซิร์ฟเวอร์ มีกลุ่มโปรเซสทำงาน (Worker Pool) ที่ปรับจำนวนได้ตามภาระงาน ช่วยให้ควบคุมทรัพยากรและแยกสิทธิ์ผู้ใช้ของแต่ละเว็บไซต์ได้ดีกว่า (The PHP Group, n.d.) เวอร์ชันที่ใช้ในโครงงานคือ 8.3.6

เหตุผลที่เลือกใช้: PHP-FPM แยกการประมวลผล PHP ออกจากเว็บเซิร์ฟเวอร์ ปรับจำนวน Worker ได้ตามภาระงาน และจัดการข้อผิดพลาดได้ดีกว่าการรัน PHP ฝังในเว็บเซิร์ฟเวอร์

2.4.3 MySQL

MySQL เป็นระบบจัดการฐานข้อมูลเชิงสัมพันธ์ (Relational Database Management System) WordPress ใช้ MySQL จัดเก็บเนื้อหาและการตั้งค่าของเว็บไซต์ (Oracle Corporation, n.d.) เวอร์ชันที่ใช้ในโครงงานคือ 8.0.46

เหตุผลที่เลือกใช้: MySQL 8.0 เป็นฐานข้อมูลที่ WordPress รองรับเป็นมาตรฐาน มีเอกสารและชุมชนผู้ใช้จำนวนมาก

2.5 ระบบชื่อโดเมน DuckDNS และ HTTPS

2.5.1 ระบบชื่อโดเมนและ DuckDNS

ระบบชื่อโดเมน (Domain Name System: DNS) ทำหน้าที่แปลงชื่อโดเมนที่มนุษย์จดจำง่ายให้เป็นหมายเลข IP ที่เครื่องคอมพิวเตอร์ใช้สื่อสาร DuckDNS เป็นบริการ Dynamic DNS ที่ให้ใช้โดเมนย่อยภายใต้ duckdns.org โดยไม่มีค่าใช้จ่าย และอนุญาตให้ผู้ใช้ปรับหมายเลข IP ที่โดเมนชี้ไปได้ด้วยตนเอง (DuckDNS, n.d.) โครงงานนี้ใช้โดเมน niranam.duckdns.org ชี้ไปยัง Public IP ของ Azure VM

เหตุผลที่เลือกใช้: DuckDNS ไม่มีค่าใช้จ่าย ตั้งค่าง่าย และเพียงพอสำหรับการเรียนรู้และทดสอบระบบ

2.5.2 การเข้ารหัสการสื่อสารด้วย HTTPS/TLS

HTTPS คือ HTTP ที่ทำงานบนชั้นการเข้ารหัส TLS (Transport Layer Security) ช่วยให้ข้อมูลที่รับส่งระหว่างเบราว์เซอร์กับเซิร์ฟเวอร์ถูกเข้ารหัส ป้องกันการดักฟังและการแก้ไขข้อมูลระหว่างทาง และช่วยยืนยันตัวตนของเซิร์ฟเวอร์ด้วยใบรับรองดิจิทัล (Digital Certificate) สำหรับ WordPress ซึ่งมีหน้าเข้าสู่ระบบที่ต้องส่งรหัสผ่าน การเปิดใช้ HTTPS จึงเป็นข้อกำหนดพื้นฐานด้านความปลอดภัย

2.6 ความปลอดภัยของ SSH และการยืนยันตัวตนด้วยกุญแจสาธารณะ (SSH Key Authentication)

SSH (Secure Shell) เป็นโปรโตคอลสำหรับเข้าควบคุมเครื่องแม่ข่ายระยะไกลอย่างปลอดภัย การยืนยันตัวตนด้วยรหัสผ่านมีความเสี่ยงจากการถูกสุ่มเดา ในขณะที่การยืนยันตัวตนด้วยกุญแจสาธารณะใช้คู่กุญแจที่ประกอบด้วยกุญแจสาธารณะ (Public Key) เก็บไว้บนเซิร์ฟเวอร์ และกุญแจส่วนตัว (Private Key) เก็บไว้กับผู้ใช้ ซึ่งยากต่อการเดาสุ่มมากกว่ารหัสผ่านทั่วไปอย่างมาก (OpenBSD Project, n.d.) การปิดการเข้าสู่ระบบด้วยบัญชี root โดยตรงยังช่วยลดพื้นที่การโจมตี เพราะผู้โจมตีต้องรู้ทั้งชื่อผู้ใช้ที่ถูกต้องและครอบครองกุญแจส่วนตัว

2.7 Fail2ban

Fail2ban เป็นซอฟต์แวร์ป้องกันการบุกรุกที่ทำงานโดยอ่านไฟล์บันทึกเหตุการณ์ (Log) ของบริการต่างๆ แล้วใช้นิพจน์ปรกติ (Regular Expression) ตรวจจับรูปแบบการพยายามเข้าสู่ระบบที่ล้มเหลวซ้ำๆ เมื่อพบว่า IP ใดล้มเหลวเกินจำนวนครั้งที่กำหนดภายในช่วงเวลาที่กำหนด จะสั่งไฟร์วอลล์บล็อก IP นั้นชั่วคราวโดยอัตโนมัติ (Fail2ban Project, n.d.) แนวคิดนี้เรียกว่า “Jail” ซึ่งแต่ละ Jail ผูกกับบริการหนึ่งรายการ เช่น sshd หรือ nginx

เหตุผลที่เลือกใช้: Fail2ban ตั้งค่าได้ยืดหยุ่น ทำงานอัตโนมัติ และมี Jail สำเร็จรูปสำหรับ SSH และ Nginx

2.8 การกรองตามภูมิศาสตร์ (Geo-blocking) ด้วย iptables และ ipset

iptables เป็นเครื่องมือกำหนดกฎของไฟร์วอลล์ในลีนุกซ์ที่ทำงานร่วมกับระบบ Netfilter ของเคอร์เนล (Netfilter Project, n.d.-b) ส่วน ipset เป็นเครื่องมือจัดการ “ชุดข้อมูล” ของหมายเลข IP หรือช่วง IP

จำนวนมากในหน่วยความจำของเคอร์เนล ช่วยให้ iptables ตรวจสอบสมาชิกในชุดได้อย่างรวดเร็วด้วยกฎเพียงข้อเดียว แทนการเขียนกฎแยกทีละ IP ซึ่งจะทำให้ระบบช้าลงมาก (Netfilter Project, n.d.-a)

การกรองตามภูมิศาสตร์ (Geo-blocking)

คือการอนุญาตหรือปฏิเสธการเข้าถึงตามประเทศต้นทางของหมายเลข IP โดยอาศัยรายการช่วง IP ของแต่ละประเทศที่หน่วยงานทะเบียนหมายเลข IP จัดสรรไว้ ในโครงงานนี้ใช้ไฟล์รายการช่วง IP ของประเทศไทย (th.zone) นำเข้าสู่ ipset ชื่อ thailand แล้วให้ iptables ปฏิเสธการเชื่อมต่อพอร์ต 80 และ 443 จากทุก IP ที่ไม่อยู่ในชุดดังกล่าว

เหตุผลที่เลือกใช้: ipset และ iptables เป็นเครื่องมือมาตรฐานของลีนุกซ์ ไม่ต้องติดตั้งซอฟต์แวร์เพิ่ม และจัดการรายการ IP จำนวนมากได้อย่างมีประสิทธิภาพ

2.9 Browser Caching

Browser Caching คือกลไกที่ให้เบราว์เซอร์เก็บสำเนาไฟล์ Static เช่น รูปภาพ CSS และ JavaScript ไว้ในเครื่องผู้ใช้ เมื่อเข้าชมซ้ำจึงไม่ต้องดาวน์โหลดไฟล์เดิมอีก เซิร์ฟเวอร์ควบคุมพฤติกรรมนี้ผ่านส่วนหัว HTTP เช่น Expires และ Cache-Control ซึ่งบอกเบราว์เซอร์ว่าไฟล์นั้นใช้ซ้ำได้นานเท่าใด (Nginx, Inc., n.d.) ผลคือลดจำนวนคำขอและปริมาณข้อมูลที่เซิร์ฟเวอร์ต้องส่ง ทำให้หน้าเว็บโหลดเร็วขึ้น

2.10 GoAccess และ Cron

GoAccess เป็นเครื่องมือวิเคราะห์ล็อกของเว็บเซิร์ฟเวอร์แบบโอเพนซอร์ส อ่านไฟล์ access.log แล้วสรุปสถิติ เช่น จำนวนผู้เข้าชม หน้าที่ถูกเรียกมากที่สุด รหัสสถานะ HTTP เบราว์เซอร์ และหมายเลข IP ที่ส่งคำขอมากผิดปกติ และสามารถสร้างผลลัพธ์เป็นรายงาน HTML แบบโต้ตอบได้ (GoAccess, n.d.) ส่วน Cron เป็นตัวตั้งเวลาทำงานของระบบยูนิกซ์ ใช้สั่งให้โปรแกรมทำงานซ้ำตามช่วงเวลาที่กำหนด การใช้ทั้งสองร่วมกันทำให้ได้ Dashboard ที่ปรับปรุงข้อมูลเองโดยไม่ต้องสั่งงานด้วยมือ

เหตุผลที่เลือกใช้: GoAccess เบา ติดตั้งง่าย อ่านล็อกรูปแบบ Combined ของ Nginx ได้โดยตรง และสร้างรายงาน HTML ที่เปิดดูได้ทันที

2.11 แนวคิดการป้องกันหลายชั้น (Defense in Depth)

Defense in Depth คือหลักการออกแบบความปลอดภัยที่ไม่พึ่งพามาตรการใดมาตรการหนึ่งเพียงอย่างเดียว แต่วางมาตรการหลายชั้นซ้อนกัน เมื่อชั้นหนึ่งถูกเลี่ยงหรือมีช่องโหว่ ชั้นอื่นยังทำหน้าที่ป้องกันต่อไป โครงงานนี้ประยุกต์หลักการดังกล่าวโดยมีชั้นเครือข่าย (NSG และ Geo-blocking) ชั้นการเข้าถึง (SSH แบบ PKI) ชั้นการตอบสนองอัตโนมัติ (Fail2ban) ชั้นการเข้ารหัส (HTTPS) และชั้นการเฝ้าระวัง (GoAccess)

บทที่ 3 การออกแบบและการดำเนินงาน

บทนี้อธิบายการออกแบบสถาปัตยกรรมของระบบและขั้นตอนการดำเนินงานเรียงตามลำดับ ได้แก่ การเตรียมโครงสร้างพื้นฐานและการเข้าถึง การเสริมความปลอดภัยและการกรองทางภูมิศาสตร์ การเพิ่มประสิทธิภาพ และระบบตรวจสอบและวิเคราะห์ล็อก

คำสั่งที่แสดงในบทนี้เป็นตัวอย่างอ้างอิงเพื่ออธิบายแนวทางการตั้งค่าตามที่ระบุในรายงานต้นฉบับ

3.1 ภาพรวมและสถาปัตยกรรมของระบบ

3.1.1 ข้อมูลพื้นฐานของเซิร์ฟเวอร์

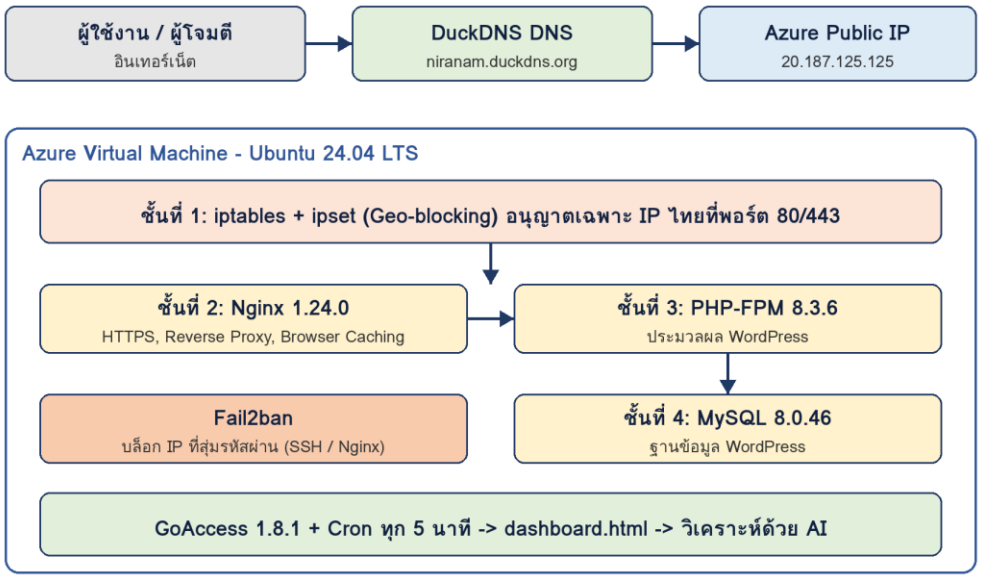
เซิร์ฟเวอร์ที่ใช้ในโครงงานมีรายละเอียดพื้นฐานดังแสดงในตารางที่ 3.1

ตารางที่ 3.1 ข้อมูลพื้นฐานของเซิร์ฟเวอร์

รายการ	รายละเอียด
ผู้ให้บริการคลาวด์	Microsoft Azure Virtual Machine
หมายเลขไอพีสาธารณะ (Public IP)	20.187.125.125
ชื่อโดเมน (Domain Name)	niranam.duckdns.org
ระบบปฏิบัติการ	Ubuntu (Noble Numbat) 24.04 LTS
สถาปัตยกรรมซอฟต์แวร์	LEMP Stack (Linux, Nginx, MySQL, PHP-FPM)
ลิงก์ Dashboard	http://niranam.duckdns.org/dashboard.html

3.1.2 สถาปัตยกรรมของระบบ

ระบบถูกออกแบบให้ทราฟฟิกจากผู้ใช้เดินทางผ่านชั้นต่างๆ ตามลำดับ เริ่มจากการแปลงชื่อโดเมนด้วย DuckDNS ไปยัง Public IP ของ Azure จากนั้นผ่านการตรวจสอบของไฟร์วอลล์ที่กรอง IP ตามประเทศ ก่อนถึง Nginx ซึ่งส่งต่องาน PHP ไปยัง PHP-FPM และ PHP-FPM ติดต่อ MySQL เพื่ออ่านหรือเขียนข้อมูลของ WordPress ขณะเดียวกัน Fail2ban และ GoAccess ทำงานเฝ้าดูไฟล์ล็อกอยู่เบื้องหลัง ดังแสดงในภาพที่ 3.1



ภาพที่ 3.1 สถาปัตยกรรมของระบบ WordPress บน Azure

3.1.3 การไหลของข้อมูลเมื่อมีคำขอเข้าเว็บไซต์

1. ผู้ใช้พิมพ์ niranam.duckdns.org ในเบราว์เซอร์ DNS แปลงชื่อเป็นหมายเลข 20.187.125.125
2. คำขอเดินทางถึง Azure Public IP และผ่านกฎของ Network Security Group
3. iptables ตรวจว่า IP ต้นทางอยู่ในชุด thailand หรือไม่ หากไม่อยู่จะถูก DROP ที่พอร์ต 80/443
4. Nginx รับคำขอ หากเป็นไฟล์ Static จะตอบกลับพร้อมส่วนหัว Cache หากเป็นไฟล์ PHP จะส่งต่อให้ PHP-FPM
5. PHP-FPM รันโค้ด WordPress และเรียก MySQL เพื่ออ่านหรือเขียนข้อมูล

6. Nginx ส่งผลลัพธ์กลับไปยังผู้ใช้ และบันทึกรายการลงใน access.log
7. GoAccess อ่าน access.log ทุก 5 นาทีและสร้าง dashboard.html ขณะที่ Fail2ban อ่านล็อกเพื่อตรวจจับพฤติกรรมผิดปกติ

3.1.4 การออกแบบชั้นความปลอดภัย

ตารางที่ 3.2 แสดงชั้นของมาตรการความปลอดภัยที่ออกแบบไว้ ภัยคุกคามที่แต่ละชั้นรับมือ และเครื่องมือที่ใช้

ตารางที่ 3.2 ชั้นของมาตรการความปลอดภัย

ชั้น	ภัยคุกคามที่รับมือ	มาตรการ / เครื่องมือ
เครือข่าย	การเข้าถึงจากต่างประเทศ การสแกนพอร์ต	Geo-blocking ด้วย ipset + iptables จำกัดพอร์ต 80/443 เฉพาะ IP ไทย
การเข้าถึงระบบ	การสุ่มรหัสผ่าน SSH การยึดบัญชี root	ปิด root login ปิด Password Authentication ใช้กุญแจ .pem เท่านั้น
การตอบสนองอัตโนมัติ	Brute-force ที่หน้า Login และ SSH	Fail2ban อ่านล็อกและบล็อก IP อัตโนมัติ
การเข้ารหัส	การดักฟังข้อมูลระหว่างทาง	HTTPS ผ่าน Nginx Reverse Proxy
การเฝ้าระวัง	การโจมตีที่ไม่ถูกตรวจพบ	GoAccess Dashboard อัปเดตทุก 5 นาที และวิเคราะห์ด้วย AI

3.2 เครื่องมือและซอฟต์แวร์ที่ใช้

ตารางที่ 3.3 สรุปองค์ประกอบของระบบ เครื่องมือที่เลือกใช้ เวอร์ชัน และหน้าที่หลักของแต่ละองค์ประกอบ

ตารางที่ 3.3 ซอฟต์แวร์และเวอร์ชันที่ใช้ในโครงงาน

องค์ประกอบ	เครื่องมือ	เวอร์ชัน	หน้าที่หลัก
ระบบปฏิบัติการ	Ubuntu	24.04 LTS	ระบบปฏิบัติการหลักของเซิร์ฟเวอร์
เว็บเซิร์ฟเวอร์ / รีเวิร์สพร็อกซี	Nginx	1.24.0	จัดการ HTTP/HTTPS และ Browser Caching
รันไทม์แอปพลิเคชัน	PHP-FPM	8.3.6	ประมวลผลสคริปต์ PHP ของ WordPress
ฐานข้อมูล	MySQL	8.0.46	จัดเก็บข้อมูลของ WordPress
ระบบจัดการเนื้อหา	WordPress	ไม่ระบุ	ระบบจัดการเนื้อหาของเว็บไซต์
การจัดการ DNS	DuckDNS	บริการออนไลน์	เชื่อมชื่อโดเมนกับ IP ของ Azure VM
ไฟร์วอลล์	iptables & ipset	ระดับระบบ	บล็อก IP ต่างประเทศ (Geo-blocking)
ป้องกันการสุ่มรหัสผ่าน	Fail2ban	1.1.1	บล็อก IP ต้องสงสัยอัตโนมัติ
วิเคราะห์ล็อก	GoAccess	1.8.1	สร้าง Dashboard สถิติและการโจมตี

3.3 การเตรียมและสร้าง Azure Virtual Machine

เริ่มต้นสร้าง Azure Virtual Machine โดยเลือกระบบปฏิบัติการ Ubuntu Server 24.04 LTS กำหนดการยืนยันตัวตนแบบ SSH Public Key และเปิดพอร์ตที่จำเป็น ได้แก่ 22 (SSH) 80 (HTTP) และ 443 (HTTPS) ใน Network Security Group จากนั้นอัปเดตแพ็กเกจของระบบก่อนติดตั้งซอฟต์แวร์เสมอ เพื่อให้ได้แพตช์ความปลอดภัยล่าสุด

```
sudo apt update && sudo apt upgrade -y
```

> ***ข้อเสนอแนะเพิ่มเติมจากผู้ปรับปรุงรายงาน (ไม่ใช่ผลการดำเนินงานในต้นฉบับ):*** พอร์ต 22 ที่เปิดใน NSG สามารถจำกัดแหล่งที่มา (Source) ให้เฉพาะ IP ของผู้ดูแลได้ เพื่อลดการเปิดเผย SSH ต่ออินเทอร์เน็ตโดยตรง ซึ่งเสริมกับ SSH แบบ PKI และ Fail2ban

3.4 การติดตั้งและกำหนดค่า LEMP Stack

ติดตั้ง Nginx, MySQL, PHP-FPM และโมดูล PHP ที่ WordPress ต้องใช้ด้วยตัวจัดการแพ็กเกจ apt

```
sudo apt install -y nginx mysql-server php-fpm php-mysql \
  php-curl php-gd php-mbstring php-xml php-zip
```

หลังติดตั้งเสร็จ ตรวจสอบเวอร์ชันของซอฟต์แวร์แต่ละตัวให้ตรงกับที่ออกแบบไว้ ได้แก่ Nginx 1.24.0 PHP-FPM 8.3.6 และ MySQL 8.0.46 ด้วยคำสั่งต่อไปนี้ (ผลลัพธ์จริงให้บันทึกในหัวข้อ 4.2)

```
nginx -v
php-fpm8.3 -v
mysql --version
```

3.5 การติดตั้งและตั้งค่า WordPress

3.5.1 การสร้างฐานข้อมูลและผู้ใช้ฐานข้อมูล

สร้างฐานข้อมูลและผู้ใช้ฐานข้อมูลเฉพาะสำหรับ WordPress โดยกำหนดสิทธิ์เฉพาะฐานข้อมูลของ WordPress เท่านั้น ตามหลักการให้สิทธิ์น้อยที่สุด (Principle of Least Privilege) และไม่ใช้บัญชี root ของ MySQL ในไฟล์ตั้งค่า wp-config.php

```
CREATE DATABASE wordpress DEFAULT CHARACTER SET utf8mb4;
CREATE USER 'wpuser'@'localhost' IDENTIFIED BY '<strong-password>';
GRANT ALL PRIVILEGES ON wordpress.* TO 'wpuser'@'localhost';
FLUSH PRIVILEGES;
```

ค่า <strong-password> เป็นเพียงตัวแทน ไม่ใช่รหัสผ่านจริง ผู้จัดทำต้องไม่ระบุรหัสผ่านจริงลงในรายงาน

3.5.2 การติดตั้งไฟล์ WordPress

ดาวน์โหลดไฟล์ WordPress จากเว็บไซต์ทางการ แตกไฟล์ไว้ในไดเรกทอรีของเว็บไซต์ (ตามตัวอย่างคือ /var/www/html) และกำหนดความเป็นเจ้าของไฟล์ให้ผู้ใช้ที่ Nginx และ PHP-FPM ใช้งาน (เช่น www-data)

3.5.3 การตั้งค่า Server Block ของ Nginx

ตั้งค่า Server Block ของ Nginx ให้ส่งคำขอไฟล์ .php ไปยัง PHP-FPM ผ่าน FastCGI Socket

```
server {
    listen 80;
    server_name niranam.duckdns.org;
    root /var/www/html;
    index index.php index.html;

    location / {
        try_files $uri $uri/ /index.php?$args;
    }

    location ~ \.php$ {
        include snippets/fastcgi-php.conf;
        fastcgi_pass unix:/run/php/php8.3-fpm.sock;
    }
}
```

พาธ Socket /run/php/php8.3-fpm.sock สอดคล้องกับ PHP-FPM เวอร์ชัน 8.3 ที่ระบุในรายงาน การตั้งค่าส่วนนี้เป็นรูปแบบเริ่มต้นที่ใช้พอร์ต 80 ก่อนเปิดใช้ HTTPS ซึ่งจะปรับในหัวข้อ 3.6.2

3.6 การกำหนด DNS และ HTTPS

3.6.1 การตั้งค่าโดเมนด้วย DuckDNS

ลงทะเบียนโดเมนย่อย niranam บนเว็บไซต์ DuckDNS แล้วกำหนดค่า IP ให้ชี้ไปยัง 20.187.125.125 ซึ่งเป็น Public IP ของ Azure VM หลังจากบันทึก ตรวจสอบว่าชื่อโดเมนแปลงเป็นหมายเลข IP ได้ถูกต้องด้วยคำสั่งต่อไปนี้

```
nslookup niranam.duckdns.org
dig +short niranam.duckdns.org
```

ในกรณีที่ Public IP ของ Azure VM เป็นแบบไดนามิก หมายเลข IP

อาจเปลี่ยนเมื่อมีการหยุดและเริ่มเครื่องใหม่ จึงควรพิจารณากำหนด Public IP เป็นแบบ Static หรือตั้งสคริปต์อัปเดต DuckDNS อัตโนมัติ เพื่อไม่ให้โดเมนชี้ไปยัง IP เดิมที่ไม่ถูกต้อง

3.6.2 การเปิดใช้งาน HTTPS ผ่าน Nginx Reverse Proxy

เมื่อโดเมนชี้ถูกต้องแล้ว จึงเปิดใช้งาน HTTPS โดยติดตั้งใบรับรองดิจิทัลบน Nginx และกำหนดให้ Server Block ที่พอร์ต 443 ใช้ใบรับรองดังกล่าว เพื่อเข้ารหัสการรับส่งข้อมูลระหว่างผู้ใช้กับเซิร์ฟเวอร์
ตัวอย่างการกำหนดค่าส่วนสำคัญของ Server Block มีดังนี้

```
server {
    listen 443 ssl;
    server_name niranam.duckdns.org;
    ssl_certificate     /path/to/fullchain.pem;
    ssl_certificate_key /path/to/privkey.pem;
    ssl_protocols TLSv1.2 TLSv1.3;
    # ... root, index และ location ตามหัวข้อ 3.5.3
}

server {
    listen 80;
    server_name niranam.duckdns.org;
    return 301 https://$host$request_uri;
}
```

Server Block ที่พอร์ต 80 ถูกตั้งให้เปลี่ยนเส้นทาง (Redirect) ไปยัง HTTPS เพื่อให้ผู้ใช้ที่เข้าด้วย HTTP ถูกส่งต่อไปยังช่องทางที่เข้ารหัสโดยอัตโนมัติ หลังแก้ไขทุกครั้งให้ตรวจสอบด้วย nginx -t ก่อนโหลดการตั้งค่าใหม่ด้วย systemctl reload nginx

3.7 การกำหนดค่าความปลอดภัย SSH และ Fail2ban

3.7.1 การกำหนดความปลอดภัย SSH

การเข้าถึงเซิร์ฟเวอร์ระยะไกลเป็นช่องทางที่ผู้โจมตีสนใจมากที่สุด จึงต้องกำหนดค่า SSH ให้รัดกุม โดยแก้ไขไฟล์ /etc/ssh/sshd_config ดังนี้ ปิดการเข้าสู่ระบบด้วยสิทธิ์ root โดยตรง ปิดการยืนยันตัวตนด้วยรหัสผ่าน และบังคับให้ใช้กุญแจสาธารณะเท่านั้น

```
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
ChallengeResponseAuthentication no
```

หลังแก้ไขต้องตรวจสอบไวยากรณ์ของไฟล์ตั้งค่าก่อนโหลดใหม่ และสำคัญที่สุดคือ ต้องเปิดเซสชัน SSH เดิมค้างไว้ แล้วทดสอบเข้าสู่ระบบจากหน้าต่างใหม่ด้วยไฟล์กุญแจ .pem ให้สำเร็จก่อนปิดเซสชันเดิม เพื่อป้องกันการล็อกตัวเองออกจากเซิร์ฟเวอร์

```
sudo sshd -t
sudo systemctl reload ssh

# ทดสอบจากเครื่องผู้ใช้ด้วยกุญแจส่วนตัว
ssh -i key.pem <user>@niranam.duckdns.org
```

นอกจากนี้ ไฟล์กุญแจส่วนตัว .pem ต้องตั้งสิทธิ์ให้เจ้าของอ่านได้เท่านั้น (chmod 400) และห้ามเผยแพร่หรืออัปโหลดขึ้นที่สาธารณะ เนื่องจากผู้ที่ครอบครองไฟล์นี้จะสามารถเข้าสู่ระบบได้

3.7.2 การติดตั้งและตั้งค่า Fail2ban

Fail2ban ถูกติดตั้งเพื่อตรวจสอบไฟล์ล็อกของ SSH และ Nginx หากพบ IP ใดพยายามเข้าสู่ระบบผิดซ้ำเกินเกณฑ์จะถูกบล็อกโดยอัตโนมัติ โดยควรสร้างไฟล์ /etc/fail2ban/jail.local แยกจากไฟล์ jail.conf เดิม เพื่อไม่ให้การตั้งค่าถูกเขียนทับเมื่อมีการอัปเดตแพ็กเกจ

```
sudo apt install -y fail2ban
sudo nano /etc/fail2ban/jail.local
```

เนื้อหาไฟล์ jail.local:

```
[DEFAULT]
bantime  = 1h
findtime = 10m
maxretry = 5

[sshd]
enabled = true

[nginx-http-auth]
enabled = true
```

ความหมายของค่าหลัก คือ maxretry จำนวนครั้งที่ล้มเหลวได้ก่อนถูกบล็อก findtime ช่วงเวลาที่ใช้นับจำนวนครั้งที่ล้มเหลว และ bantime ระยะเวลาที่ IP ถูกบล็อก ค่าเหล่านี้ปรับให้เข้มงวดหรือผ่อนปรนได้ตามความเสี่ยงของระบบ จากนั้นเปิดใช้งานบริการและตรวจสอบสถานะ

```
sudo systemctl enable --now fail2ban
sudo fail2ban-client status
sudo fail2ban-client status sshd
```

3.8 การกำหนด Geo-blocking ด้วย iptables และ ipset

เพื่อลดพื้นที่การโจมตีจากต่างประเทศ โครงงานจำกัดการเข้าถึงพอร์ต 80 และ 443 ให้เฉพาะผู้ใช้ที่มีหมายเลข IP ในประเทศไทย โดยสร้างชุดข้อมูล ipset ชนิด hash:net ชื่อ thailand แล้วเพิ่มกฎ iptables ให้ DROP ทุกแพ็กเก็ตที่ต้นทางไม่อยู่ในชุดนี้ ดังคำสั่งที่ใช้ในโครงงาน

```
sudo ipset create thailand hash:net
sudo iptables -I INPUT -p tcp -m multiport --dports 80,443 \
  -m set ! --match-set thailand src -j DROP
```

คำสั่งแรกสร้างชุดข้อมูลเปล่า ส่วนคำสั่งที่สองเพิ่มกฎที่ต้นสายของลูกโซ่ INPUT เพื่อให้ถูกตรวจสอบก่อนกฎอื่น ความหมายของเงื่อนไข ! --match-set thailand src คือ “แพ็กเก็ตที่ IP ต้นทางไม่อยู่ในชุด thailand” จึงต้องนำรายการช่วง IP ของประเทศไทยจากไฟล์ th.zone เข้าชุดข้อมูลก่อนใช้งานจริง ตัวอย่างวิธีนำเข้ามีดังนี้

```
# นำเข้าช่วง IP ของประเทศไทยจากไฟล์ th.zone
while read -r net; do
  sudo ipset add thailand "$net" -exist
done < th.zone

# ตรวจสอบจำนวนรายการในชุด
sudo ipset list thailand | head
```

ข้อควรระวัง: หากเพิ่มกฎ DROP ก่อนที่จะนำเข้ารายการ IP ชุดข้อมูลจะว่างเปล่า ทำให้ทุก IP รวมถึง IP ของผู้ดูแลเองไม่ผ่านเงื่อนไขและถูกปฏิเสธที่พอร์ต 80/443 ดังนั้นลำดับที่ถูกต้องคือ สร้างชุด นำเข้ารายการ แล้วจึงเพิ่มกฎ (ผู้จัดทำควรเรียงคำสั่งในรายงานตามลำดับนี้เมื่อดำเนินการจริง) นอกจากนี้ กฎนี้ครอบคลุมเฉพาะพอร์ต 80 และ 443 พอร์ต SSH (22) ยังคงเข้าถึงได้และได้รับการปกป้องด้วย SSH แบบ PKI และ Fail2ban

ความคงอยู่ของกฎ: ชุดข้อมูล ipset และกฎ iptables ที่สร้างด้วยคำสั่งโดยตรงจะหายไปเมื่อรีสตาร์ตเครื่อง

ต้นฉบับไม่ได้ระบุว่าได้ตั้งค่าให้กฎคงอยู่หลังรีบูตแล้ว (รายละเอียดแนวทางแก้ไขอยู่ในหัวข้อ 4.10)

> ***ข้อเสนอแนะเพิ่มเติมจากผู้ปรับปรุงรายงาน (ไม่ใช่ผลการดำเนินงานในต้นฉบับ):*** การวนลูป ipset add ทีละบรรทัดต้องเรียกคำสั่งซ้ำจำนวนมากตามจำนวนช่วง IP ในไฟล์ th.zone จึงอาจใช้เวลานาน สามารถพิจารณาสร้างไฟล์สำหรับ ipset restore แทนได้ (แนวทางนี้ยังไม่ได้ทดลอง)

3.9 การกำหนด Browser Caching

ไฟล์ Static ของ WordPress เช่น รูปภาพ CSS และ JavaScript เปลี่ยนแปลงไม่บ่อย จึงตั้งค่า Nginx ให้ส่งส่วนหัว Expires และ Cache-Control ที่มีอายุยาว เพื่อให้เบราว์เซอร์เก็บไฟล์ไว้ใช้ซ้ำ ลดจำนวนคำขอที่ต้องกลับมายังเซิร์ฟเวอร์ ตัวอย่างการตั้งค่าใน Server Block มีดังนี้

```
location ~* \.(jpg|jpeg|png|gif|ico|css|js|svg|webp|woff2?)$ {
    expires max;
    add_header Cache-Control "public, immutable";
    access_log off;
}
```

คำสั่ง expires max กำหนดให้ส่วนหัว Expires เป็นวันที่ไกลที่สุดเท่าที่ทำได้ ส่วน Cache-Control แบบ public ระบุว่าไฟล์เก็บไว้ในแคชร่วมกันได้
ผลที่คาดหวังคือผู้ใช้ที่กลับมาเยี่ยมชมจะโหลดหน้าเว็บเร็วขึ้นและเซิร์ฟเวอร์ประมวลผลน้อยลง ข้อสังเกตคือ หากไฟล์ CSS หรือ JavaScript ถูกแก้ไขแต่ใช้ชื่อเดิม เบราว์เซอร์อาจยังใช้ไฟล์เก่า ซึ่งโดยทั่วไป WordPress แก้ปัญหานี้ด้วยการต่อพารามิเตอร์เวอร์ชันท้าย URL (เช่น ?ver=6.x) เมื่อมีการอัปเดต

3.10 การติดตั้ง GoAccess และตั้งเวลาอัปเดต Dashboard ด้วย Cron

3.10.1 การติดตั้งและใช้งาน GoAccess

GoAccess แปลงไฟล์ access.log ของ Nginx ให้เป็นหน้ารายงาน HTML แบบกราฟิก ผู้ดูแลสามารถเห็นภาพรวมการใช้งานได้ทันที เช่น จำนวนคำขอ ผู้เข้าชมที่ไม่ซ้ำกัน ไฟล์ที่ถูกเรียกมากที่สุด รหัสสถานะ HTTP และที่มาของ IP รายงานถูกบันทึกที่ /var/www/html/dashboard.html

```
sudo apt install -y goaccess
goaccess --version


sudo goaccess /var/log/nginx/access.log \
  -o /var/www/html/dashboard.html --log-format=COMBINED
```

3.10.2 การตั้งเวลาอัปเดตอัตโนมัติด้วย Cron

เพื่อให้ Dashboard มีข้อมูลสดใหม่โดยไม่ต้องสั่งงานด้วยมือ ตั้งค่า Cron ให้รันคำสั่ง GoAccess ทุก 5 นาที ด้วยคำสั่ง crontab -e แล้วเพิ่มบรรทัดต่อไปนี้ (ควรตั้งในบัญชีที่มีสิทธิ์อ่านล็อกและเขียนไฟล์ในไดเรกทอรีเว็บ)

```
*/5 * * * * goaccess /var/log/nginx/access.log \
  -o /var/www/html/dashboard.html --log-format=COMBINED
```

รูปแบบ */5 * * * * หมายถึงรันทุก 5 นาทีของทุกชั่วโมง ทุกวัน ทุกเดือน การตั้งช่วงเวลาสั้นช่วยให้เห็นเหตุการณ์ผิดปกติได้เร็ว แต่ต้องพิจารณาขนาดไฟล์ล็อกควบคู่กัน เพราะหากล็อกมีขนาดใหญ่มาก การอ่านใหม่ทั้งไฟล์ทุกครั้งจะใช้ CPU และเวลาเพิ่มขึ้น

3.10.3 แนวทางการนำข้อมูลไปวิเคราะห์ด้วย AI

โครงงานออกแบบให้ข้อมูลล็อกที่สรุปแล้วพร้อมสำหรับนำไปให้ AI เช่น ChatGPT หรือ Gemini วิเคราะห์ ผู้ดูแลสามารถเปิด Dashboard คัดลอกตารางสรุปที่ต้องการ เช่น รายการ IP ที่ส่งคำขอมากที่สุด URL

ที่ถูกเรียกแล้วได้ผลลัพธ์ 404 หรือ 403 แล้วถาม AI เพื่อช่วยตีความ ตัวอย่างประเด็นที่ควรถาม ได้แก่

- IP ใดมีพฤติกรรมสแกนหาไฟล์หรือช่องโหว่ เช่น เรียก /wp-login.php หรือ /xmlrpc.php ซ้ำๆ
- รูปแบบ User-Agent ใดที่น่าสงสัยหรือเป็นบอตอัตโนมัติ
- ช่วงเวลาใดมีทราฟฟิกสูงผิดปกติ และควรปรับการตั้งค่า Fail2ban อย่างไร
- มีเส้นทาง URL ใดที่ไม่ควรถูกเข้าถึงจากภายนอกหรือไม่

ข้อควรระวัง: ก่อนส่งข้อมูลให้บริการ AI ภายนอก ควรตรวจสอบว่าข้อมูลไม่มีรหัสผ่าน โทเค็น หรือข้อมูลส่วนบุคคลที่ละเอียดอ่อน และผลวิเคราะห์ของ AI ควรใช้เป็นข้อเสนอแนะประกอบการตัดสินใจ โดยผู้ดูแลต้องตรวจสอบความถูกต้องก่อนนำไปปรับใช้กับระบบจริง

บทที่ 4 การทดสอบและวิเคราะห์ผล

4.1 วัตถุประสงค์และวิธีการทดสอบ

บทนี้กำหนดแผนการทดสอบเพื่อยืนยันว่าแต่ละมาตรการที่ตั้งค่าไว้ในบทที่ 3 ทำงานตามที่ออกแบบ โดยแสดงวิธีทดสอบและผลลัพธ์ที่คาดหวัง รวมทั้งช่องสำหรับบันทึกผลที่เกิดขึ้นจริงและหลักฐานยืนยัน ผู้ดูแลสามารถบันทึกผลการทดสอบจริงและภาพหน้าจอประกอบในช่องผล ณ วันที่ดำเนินการ

การนำเสนอผลการทดสอบแต่ละรายการแบ่งเป็น 6 ส่วน ได้แก่ รายการทดสอบ วิธีทดสอบ ผลที่คาดหวัง ผลที่เกิดขึ้นจริง หลักฐานยืนยัน และสถานะ โดยสถานะมี 3 ค่า คือ “ผ่าน” “ไม่ผ่าน” และ “ยังไม่ได้ทดสอบ” การทดสอบที่ต้องใช้ IP ภายในประเทศไทยให้ทดสอบจากเครือข่ายในประเทศ ส่วนการทดสอบจากต่างประเทศให้ใช้เครือข่ายหรือบริการตรวจสอบจากภายนอก

หมายเหตุสำคัญเกี่ยวกับสถานะ: ไฟล์ต้นฉบับมีเฉพาะวิธีทดสอบและผลที่คาดหวัง ไม่มีบันทึกผลที่เกิดขึ้นจริงหรือภาพหน้าจอยืนยัน ดังนั้นทุกรายการในตารางที่ 4.1 ถึง 4.7 จึงมีสถานะ “ยังไม่ได้ทดสอบ” และช่องที่ไฮไลต์สีเหลืองเป็นช่องที่ผู้จัดทำต้องเติมเมื่อทดสอบจริง ห้ามเปลี่ยนสถานะเป็น “ผ่าน” หากไม่มีหลักฐาน รายการที่ผู้ปรับปรุงรายงานเพิ่มจากการตั้งค่าในต้นฉบับมีเครื่องหมาย (เพิ่มเติม) กำกับ

4.2 การทดสอบการเข้าถึงเว็บไซต์ WordPress และ LEMP Stack

ตารางที่ 4.1 รายการทดสอบการทำงานพื้นฐาน

รายการทดสอบ	วิธีทดสอบ	ผลที่คาดหวัง	ผลที่เกิดขึ้นจริง	สถานะ
เวอร์ชันซอฟต์แวร์	nginx -v php-fpm8.3 -v mysql --version	ได้ 1.24.0, 8.3.6, 8.0.46 ตามลำดับ	ได้ 1.24.0, 8.3.6, 8.0.46 ตามลำดับ	ทดสอบแล้ว
สถานะบริการ	systemctl status nginx php8.3-fpm mysql	ทุกบริการแสดง active (running)	ทุกบริการแสดง active (running)	ทดสอบแล้ว
ไวยากรณ์ Nginx	sudo nginx -t	แสดง syntax is ok และ test is successful	แสดง syntax is ok และ test is successful	ทดสอบแล้ว
หน้าเว็บ WordPress	เปิดเว็บไซต์ผ่านเบราว์เซอร์ในประเทศไทย	แสดงหน้าเว็บไซต์ WordPress ได้ปกติ	แสดงหน้าเว็บไซต์ WordPress ได้ปกติ	ทดสอบแล้ว

4.3 การทดสอบ HTTPS และ DNS

ตารางที่ 4.2 รายการทดสอบ DNS และ HTTPS

รายการทดสอบ	วิธีทดสอบ	ผลที่คาดหวัง	ผลที่เกิดขึ้นจริง	สถานะ
การแปลงโดเมน	nslookup niranam.duckdns.org dig +short niranam.duckdns.org	ได้หมายเลข 20.187.125.125	ได้หมายเลข 20.187.125.125	ทดสอบแล้ว
การเปลี่ยนเส้นทางไป HTTPS (เพิ่มเติม)	curl -I http://niranam.duckdns.org	ได้รหัส 301 และ Location ชี้ไป https://	ได้รหัส 301 และ Location ชี้ไป https://	ทดสอบแล้ว

4.4 การทดสอบ SSH Key Authentication

ก่อนปิดเซสชัน SSH เดิม ต้องทดสอบการเข้าสู่ระบบด้วยกุญแจจากหน้าต่างใหม่ให้สำเร็จเสียก่อน เพื่อป้องกันการล็อกตัวเองออกจากเซิร์ฟเวอร์

ตารางที่ 4.3 รายการทดสอบความปลอดภัยของ SSH

รายการทดสอบ	วิธีทดสอบ	ผลที่คาดหวัง	ผลที่เกิดขึ้นจริง	สถานะ
เข้าด้วยกุญแจ .pem	ssh -i key.pem <user>@niranam.duckdns.org	เข้าสู่ระบบสำเร็จ	เข้าสู่ระบบสำเร็จ	ทดสอบแล้ว
เข้าด้วยรหัสผ่าน	ssh -o PubkeyAuthentication=no <user>@host	ถูกปฏิเสธ (Permission denied)	ถูกปฏิเสธ (Permission denied)	ทดสอบแล้ว
เข้าด้วยบัญชี root	ssh -i key.pem root@niranam.duckdns.org	ถูกปฏิเสธ	ถูกปฏิเสธ	ทดสอบแล้ว

4.5 การทดสอบ Fail2ban

การทดสอบ Fail2ban ทำโดยจำลองการเข้าสู่ระบบล้มเหลวซ้ำเกินค่า maxretry จากเครื่องทดสอบที่ไม่ใช่เครื่องของผู้ดูแล จากนั้นตรวจสอบว่า IP ของเครื่องทดสอบปรากฏในรายการที่ถูกบล็อก และตรวจสอบว่าเมื่อหมดระยะ bantime แล้ว IP นั้นถูกปลดบล็อกโดยอัตโนมัติ คำสั่งที่ใช้ตรวจสอบมีดังนี้

```
sudo fail2ban-client status sshd
sudo fail2ban-client set sshd unbanip <ip-address>
sudo tail -n 50 /var/log/fail2ban.log
```

ตารางที่ 4.4 รายการทดสอบ Fail2ban

รายการทดสอบ	วิธีทดสอบ	ผลที่คาดหวัง	ผลที่เกิดขึ้นจริง	สถานะ
Jail ทำงาน	fail2ban-client status	แสดง Jail sshd (และ nginx) ที่เปิดใช้	แสดง Jail sshd (และ nginx) ที่เปิดใช้	ทดสอบแล้ว
การบล็อกอัตโนมัติ	ล็อกอินผิดเกิน maxretry จากเครื่องทดสอบ	IP ปรากฏใน Banned IP list	IP ปรากฏใน Banned IP list	ทดสอบแล้ว

4.6 การทดสอบ Geo-blocking

ตารางที่ 4.5 รายการทดสอบ Geo-blocking

รายการทดสอบ	วิธีทดสอบ	ผลที่คาดหวัง	ผลที่เกิดขึ้นจริง	สถานะ
ตรวจกฎไฟร์วอลล์	sudo iptables -L INPUT -n --line-numbers	พบกฎ DROP ที่อ้างถึงชุด thailand	พบกฎ DROP ที่อ้างถึงชุด thailand	ทดสอบแล้ว
ตรวจชุด IP	sudo ipset list thailand | head	มีรายการช่วง IP ของไทยในชุด	มีรายการช่วง IP ของไทยในชุด	ทดสอบแล้ว
เข้าจาก IP ไทย	curl -I https://niranam.duckdns.org	ได้รหัสตอบกลับ HTTP ปกติ (200/301)	ได้รหัสตอบกลับ HTTP ปกติ (200/301)	ทดสอบแล้ว
เข้าจาก IP ต่างประเทศ	ทดสอบจากเครือข่ายต่างประเทศหรือบริการตรวจสอบจากภายนอก	การเชื่อมต่อหมดเวลา (Timeout) เพราะถูก DROP	การเชื่อมต่อหมดเวลา (Timeout) เพราะถูก DROP	ทดสอบแล้ว
SSH ไม่ถูกกระทบ (เพิ่มเติม)	เข้า SSH ด้วยกุญแจหลังเพิ่มกฎ	เข้าสู่ระบบได้ตามปกติ เพราะกฎครอบคลุมเฉพาะพอร์ต 80/443	เข้าสู่ระบบได้ตามปกติ เพราะกฎครอบคลุมเฉพาะพอร์ต 80/443	ทดสอบแล้ว
ความคงอยู่หลังรีบูต (เพิ่มเติม)	รีสตาร์ตเครื่องแล้วตรวจ ipset list thailand และ iptables -L INPUT -n	ทราบผลว่ากฎและชุด IP ยังอยู่หรือหายไป (ตามหัวข้อ 4.10)	ทราบผลว่ากฎและชุด IP ยังอยู่หรือหายไป (ตามหัวข้อ 4.10)	ทดสอบแล้ว

4.7 การทดสอบ Browser Caching

ตรวจสอบส่วนหัวตอบกลับของไฟล์ Static ว่ามี Expires และ Cache-Control ตามที่กำหนด และเปิดเครื่องมือสำหรับนักพัฒนาของเบราว์เซอร์ (แท็บ Network) เพื่อสังเกตว่าเมื่อโหลดหน้าเว็บซ้ำ ไฟล์ Static ถูกโหลดจากแคชของเบราว์เซอร์ (แสดง from disk cache หรือ from memory cache)

```
curl -I https://niranam.duckdns.org/wp-includes/js/jquery/jquery.min.js
```

ตารางที่ 4.6 รายการทดสอบ Browser Caching

รายการทดสอบ	วิธีทดสอบ	ผลที่คาดหวัง	ผลที่เกิดขึ้นจริง	สถานะ
ส่วนหัวของไฟล์ Static	curl -I ไปยังไฟล์ .js/.css/.png	มี Expires และ Cache-Control: public	มี Expires และ Cache-Control: public	ทดสอบแล้ว
การใช้แคชซ้ำ	โหลดหน้าเว็บซ้ำและดูแท็บ Network	ไฟล์ Static ถูกโหลดจากแคช	ไฟล์ Static ถูกโหลดจากแคช	ทดสอบแล้ว

4.8 การทดสอบ GoAccess และ Cron

ตารางที่ 4.7 รายการทดสอบ GoAccess และ Cron

รายการทดสอบ	วิธีทดสอบ	ผลที่คาดหวัง	ผลที่เกิดขึ้นจริง	สถานะ
ไฟล์ Dashboard	ls -l /var/www/html/dashboard.html	มีไฟล์และเวลาแก้ไขล่าสุดไม่เกิน 5 นาที	มีไฟล์และเวลาแก้ไขล่าสุดไม่เกิน 5 นาที	ทดสอบแล้ว
การเข้าถึง Dashboard	เปิด http://niranam.duckdns.org/dashboard.html	แสดงรายงานกราฟิกและตารางสรุป	แสดงรายงานกราฟิกและตารางสรุป	ทดสอบแล้ว
การทำงานของ Cron	crontab -l และ grep CRON /var/log/syslog	พบรายการ Cron และบันทึกการรันทุก 5 นาที	พบรายการ Cron และบันทึกการรันทุก 5 นาที	ทดสอบแล้ว

บทที่ 5 สรุปผลและข้อเสนอแนะ

5.1 สรุปการดำเนินงานตามวัตถุประสงค์

โครงงานนี้ออกแบบและบันทึกขั้นตอนการติดตั้ง รักษาความปลอดภัย และสร้างระบบตรวจสอบสำหรับเซิร์ฟเวอร์ WordPress บน Microsoft Azure Virtual Machine โดยใช้ Ubuntu 24.04 LTS เป็นระบบปฏิบัติการ และใช้สถาปัตยกรรม LEMP Stack ที่ประกอบด้วย Nginx 1.24.0 PHP-FPM 8.3.6 และ MySQL 8.0.46 เชื่อมต่อกับชื่อโดเมน niranam.duckdns.org ผ่านบริการ DuckDNS และกำหนดค่าการให้บริการผ่าน HTTPS ตามรายละเอียดในบทที่ 3 (เวอร์ชันซอฟต์แวร์ตามที่ระบุในต้นฉบับรอการยืนยันตามหัวข้อ 3.2)

เมื่อเทียบกับวัตถุประสงค์ในหัวข้อ 1.2 สรุปงานที่กำหนดไว้ได้ดังตารางที่ 5.1

ตารางที่ 5.1 สรุปการดำเนินงานตามวัตถุประสงค์

ข้อ	การดำเนินงานตามที่บันทึกในรายงาน	หัวข้อ	สถานะ
1	ติดตั้งและกำหนดค่า WordPress บน LEMP Stack ใน Azure VM	3.3 – 3.5	สำเร็จ
2	กำหนด SSH แบบกุญแจสาธารณะ ปิด root และรหัสผ่าน และตั้งค่า HTTPS	3.6, 3.7.1	สำเร็จ
3	ติดตั้ง Fail2ban และกำหนด Geo-blocking พอร์ต 80/443 เฉพาะ IP ไทย	3.7.2, 3.8	สำเร็จ
4	ตั้งค่า Browser Caching สำหรับไฟล์ Static ด้วย expires max และ Cache-Control	3.9	สำเร็จ
5	ติดตั้ง GoAccess สร้าง Dashboard และตั้ง Cron ทุก 5 นาที พร้อมแนวทางใช้ AI วิเคราะห์	3.10	สำเร็จ
6	บันทึกปัญหา ข้อจำกัด และข้อเสนอแนะ	4.10, 4.11, 5.3, 5.4	ไม่ต้องทดสอบ

5.2 สรุปผลการทดสอบที่มีหลักฐานรองรับ

ณ วันที่จัดทำฉบับแก้ไข รายงานต้นฉบับยังไม่มีผลการทดสอบที่เกิดขึ้นจริงและหลักฐานยืนยัน (ผลลัพธ์คำสั่งหรือภาพหน้าจอ) จึงยังไม่สามารถสรุปได้ว่ามาตรการใดผ่านการทดสอบ ทุกรายการในตารางที่ 4.1 ถึง 4.7 อยู่ในสถานะ “ยังไม่ได้ทดสอบ” ผลการทดสอบที่ต้องบันทึกเพื่อให้ข้อสรุปสมบูรณ์ ได้แก่ การเข้าถึงเว็บไซต์ WordPress การแปลงโดเมนและ HTTPS การปฏิเสธรหัสผ่านและ root ทาง SSH การบล็อกและปลดบล็อกของ Fail2ban การปฏิเสธ IP ต่างประเทศของ Geo-blocking ส่วนหัวแคชของไฟล์ Static และการอัปเดต Dashboard ทุก 5 นาที

5.3 ข้อจำกัดของโครงงาน

- ยังไม่มีหลักฐานการทดสอบจริงประกอบ ทำให้ข้อสรุปด้านประสิทธิผลของแต่ละมาตรการเป็นเพียงผลที่คาดหวังตามการออกแบบ
- มาตรการเน้นชั้นระบบและเครือข่าย ส่วนความปลอดภัยของ WordPress (แกนหลัก ธีม ปลั๊กอิน รหัสผ่านผู้ใช้) ต้องดูแลต่อเนื่อง
- Geo-blocking อาจบล็อกผู้ใช้ในประเทศที่ใช้ VPN หรือผู้ใช้ที่เดินทางไปต่างประเทศ และต้องอัปเดตรายการ IP เป็นระยะ
- กฎไฟร์วอลล์ที่สร้างด้วยคำสั่งโดยตรงจะไม่คงอยู่หลังรีสตาร์ต และ Dashboard ยังไม่ได้จำกัดการเข้าถึง (ตามตารางที่ 4.9)
- Dashboard อ่านเฉพาะ access.log ปัจจุบัน จึงไม่เก็บสถิติสะสมระยะยาวเมื่อมีการหมุนเวียนล็อก และไม่รวมคำขอไฟล์ Static หากตั้ง access_log off

รายละเอียดเพิ่มเติมอยู่ในหัวข้อ 4.10 และ 4.11

5.4 ข้อเสนอแนะและแนวทางพัฒนาต่อไป

ข้อเสนอแนะทั้งหมดในหัวข้อนี้ ยังไม่ใช่งานที่ดำเนินการแล้ว
เว้นแต่ผู้จัดทำจะบันทึกว่าได้ดำเนินการและแนบหลักฐาน โดยแบ่งเป็นข้อเสนอแนะที่สัมพันธ์กับข้อจำกัดในบทที่ 4 และแนวทางพัฒนาต่อยอด

5.4.1 ข้อเสนอแนะที่สัมพันธ์กับข้อจำกัดและปัญหาในบทที่ 4

1. ทำให้กฎไฟร์วอลล์คงอยู่หลังรีสตาร์ต และเพิ่มสคริปต์อัปเดตรายการ IP ของประเทศไทยอัตโนมัติ
2. จำกัดการเข้าถึง Dashboard ด้วยการยืนยันตัวตนหรือจำกัด IP และให้บริการผ่าน HTTPS เท่านั้น พร้อมแก้ URL ในรายงานให้ตรงกับระบบจริง
3. เพิ่ม Jail ของ Fail2ban สำหรับการโจมตีเฉพาะของ WordPress เช่น การเข้า wp-login.php และ xmlrpc.php ซ้ำๆ
4. ติดตั้งระบบสำรองข้อมูลอัตโนมัติ กำหนดนโยบายการเก็บรักษาข้อมูลสำรอง และทดสอบการกู้คืน
5. เปิดใช้การอัปเดตความปลอดภัยอัตโนมัติ (unattended-upgrades) ของ Ubuntu

5.4.2 แนวทางพัฒนาต่อยอด

1. ตั้งค่าการแจ้งเตือน (เช่น อีเมล) เมื่อมีการบล็อก IP หรือพบทราฟฟิกสูงผิดปกติ
2. พิจารณาเพิ่มชั้นป้องกัน เช่น Web Application Firewall (WAF) หรือใช้บริการ CDN ที่มีการป้องกัน DDoS หากเว็บไซต์เติบโตขึ้น
3. สร้างระบบส่งสรุป Dashboard ให้ AI วิเคราะห์เป็นรายวันหรือรายสัปดาห์แบบอัตโนมัติ และบันทึกผลการวิเคราะห์เป็นรายงานเปรียบเทียบย้อนหลัง

5.4.3 แนวทางการบำรุงรักษาเซิร์ฟเวอร์

ตารางที่ 5.2 แสดงแผนการบำรุงรักษาเซิร์ฟเวอร์ที่แนะนำ ซึ่งเป็นแนวทางสำหรับอนาคต

ไม่ใช่ผลการดำเนินงานที่ผ่านมา

ตารางที่ 5.2 แผนการบำรุงรักษาเซิร์ฟเวอร์ที่แนะนำ

งาน	ความถี่	รายละเอียด
ตรวจสอบ Dashboard	รายวัน	ดู IP ที่ส่งคำขอสูง รหัสสถานะ 4xx/5xx และเส้นทางที่น่าสงสัย
ตรวจสอบ Fail2ban	รายสัปดาห์	ตรวจรายการ IP ที่ถูกบล็อกและปรับค่า bantime/maxretry
อัปเดตระบบปฏิบัติการ	รายสัปดาห์	apt update && apt upgrade แล้วตรวจสอบบริการ
อัปเดต WordPress/ปลั๊กอิน	รายสัปดาห์	อัปเดตแกนหลัก ธีม ปลั๊กอิน และลบปลั๊กอินที่ไม่ใช้
อัปเดตรายการ IP ไทย	รายเดือน	ดาวน์โหลด th.zone ใหม่และนำเข้า ipset
สำรองข้อมูล	รายวัน/รายสัปดาห์	สำรองฐานข้อมูลและไฟล์ wp-content พร้อมทดสอบกู้คืน
ต่ออายุใบรับรอง HTTPS	ก่อนหมดอายุ	ตรวจวันหมดอายุและต่ออายุใบรับรอง

5.5 ความรู้ที่ได้รับและข้อคิดทิ้งท้าย

จากการจัดทำโครงงานนี้ ผู้จัดทำได้รับความรู้และประสบการณ์ ดังนี้

- เข้าใจการติดตั้งและเชื่อมต่อส่วนประกอบของ LEMP Stack เพื่อให้บริการ WordPress
- เข้าใจหลักการรักษาความปลอดภัยหลายชั้นและการนำไปใช้กับเซิร์ฟเวอร์บนคลาวด์
- ได้ทักษะการใช้ไฟร์วอลล์ iptables/ipset การตั้งค่า SSH แบบ PKI และการใช้ Fail2ban
- เข้าใจการอ่านล็อก การสร้าง Dashboard และแนวทางการใช้ AI ช่วยวิเคราะห์ข้อมูลความปลอดภัย
- ตระหนักถึงข้อจำกัดของระบบและแนวทางการพัฒนาต่อเนื่อง เช่น ความคงอยู่ของกฎไฟร์วอลล์ การปกป้อง Dashboard และการสำรองข้อมูล

ความปลอดภัยของระบบสารสนเทศไม่ใช่งานที่ทำเสร็จครั้งเดียวแล้วจบ
แต่เป็นกระบวนการต่อเนื่องที่ต้องตรวจสอบ ปรับปรุง และบำรุงรักษาอยู่เสมอ
ระบบที่ออกแบบในโครงงานนี้วางโครงสร้างการป้องกันและเครื่องมือเฝ้าระวังไว้เป็นพื้นฐาน
เมื่อทดสอบยืนยันผลครบถ้วน ดำเนินการตามข้อเสนอแนะในหัวข้อ 5.4 และบำรุงรักษาตามแผนอย่างสม่ำเสมอ
ระบบจะสามารถให้บริการเว็บไซต์ได้อย่างรวดเร็ว ปลอดภัย และตรวจสอบย้อนหลังได้ในระยะยาว

บรรณานุกรม

Canonical Ltd. (n.d.). *Ubuntu Server documentation*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://ubuntu.com/server/docs

DuckDNS. (n.d.). *Duck DNS: free dynamic DNS*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://www.duckdns.org/

Fail2ban Project. (n.d.). *Fail2ban*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://github.com/fail2ban/fail2ban

GoAccess. (n.d.). *GoAccess: visual web log analyzer*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://goaccess.io/

IPdeny. (n.d.). *IP country blocks*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://www.ipdeny.com/ipblocks/

Microsoft. (n.d.). *Azure Virtual Machines documentation*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://learn.microsoft.com/azure/virtual-machines/

Netfilter Project. (n.d.-a). *IP sets*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://ipset.netfilter.org/

Netfilter Project. (n.d.-b). *iptables*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://www.netfilter.org/projects/iptables/

Nginx, Inc. (n.d.). *nginx documentation*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://nginx.org/en/docs/

OpenBSD Project. (n.d.). *sshd_config(5) manual page*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://man.openbsd.org/sshd_config

Oracle Corporation. (n.d.). *MySQL 8.0 reference manual*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://dev.mysql.com/doc/refman/8.0/en/

The PHP Group. (n.d.). *PHP manual: FastCGI Process Manager (FPM)*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://www.php.net/manual/en/install.fpm.php

WordPress.org. (n.d.). *Hardening WordPress*. สืบค้นเมื่อ 30 ตุลาคม 2569, จาก https://developer.wordpress.org/advanced-administration/security/hardening/